

TryNex Lifestyle

Comprehensive A-to-Z Site Audit & Prioritized Fix Plan

Live site: <https://trynexshop.com>

Date: **July 19, 2026**

Scope: Frontend, Backend, Design Studio, Mockups, 3D, Mobile, SEO, Performance

This report combines live end-to-end testing, code inspection, workflow diagnostics, and search-ranking checks. It is followed by a 30-day prioritized fix plan.

Auditor: Senior Full-Stack Audit (Replit Agent)

1. Methodology

The audit used four parallel evidence streams: (1) live HTTP/HTTPS fetching and screenshot capture of trynexshop.com across desktop and mobile viewports; (2) direct source-code inspection of the pnpm monorepo (storefront, API server, mobile app, promo); (3) workflow log and browser console review; and (4) targeted web-search for branded search visibility. Because squirreldscan was not available in this workspace, the assessment is manual and reproducible: every finding is tied to a specific file, line range, or live response.

Tools used: webFetch, curl, screenshots, ripgrep, TypeScript compiler, Metro/web workflow logs, reportlab (PDF generation).

Limitations: No automated crawler scan; payment gateway live transactions were not executed; admin panel functionality was inspected via code only because admin credentials were not used.

2. Executive Summary

TryNexshop.com is **live and functional**: the homepage, product catalog, design studio, and checkout all respond HTTP 200, the API health endpoint returns {"status":"ok"}, and the build/typecheck for the storefront is clean. However, the live site has several **critical and high-severity** issues that degrade revenue, security, and operational trust.

Top 5 risks:

- **Security:** The API server auto-saves the GitHub personal access token (PAT) from the environment into the database settings table, making it retrievable if the admin panel is compromised.
- **Database:** API logs show the primary Neon DB is unreachable and backup-sync targets are failing because the Neon project has exceeded its data-transfer quota.
- **SEO:** Product detail pages do not emit JSON-LD structured data correctly; search visibility for TryNex-branded terms is weak.
- **Mobile:** The Expo mobile app has hardcoded Bangladesh districts and Alert.alert validation that behaves differently on web, risking checkout abandonment.
- **Design Studio:** The gesture/drag system and selection-handle UX were previously patched, but the user-reported pain points around print-zone ratios, asset alignment, and blended realism remain partially disputed; asset files still include the deprecated *-cutout-new.png variants alongside the recommended *-cutout-real.png files.

Overall verdict: The product is monetizable but needs immediate hardening (security + DB) and a focused 30-day polish sprint to improve conversion and search ranking.

3. Infrastructure & Health

3.1 Live site status

All core pages return HTTP 200 with Cloudflare caching set to DYNAMIC. The API health endpoint `/api/healthz` returns `{"status":"ok"}`. The homepage meta description and Open Graph tags are present and well written. The robots.txt is permissive for Google/Bing but explicitly blocks AI crawlers (ClaudeBot, GPTBot, Google-Extended), which is acceptable for IP protection.

Observed live URLs: `/` (200), `/products` (200), `/design-studio` (200), `/product/couple-tshirt-set` (200), `/checkout` (200), `/admin` (200), `/api/healthz` (200), `/api/sitemap.xml` (200).

3.2 Database & backup sync

Critical

API server logs reveal: "[DB] Primary unreachable or empty. Switched to fallback #2" and "Your project has exceeded the data transfer quota. Upgrade your plan to increase limits." for all three backup-sync targets (Neon Failover, Products shard, Analytics shard). The scheduler is therefore running daily backup-sync jobs that repeatedly fail. This is a real operational issue, not a UI mismatch.

Recommendation: (1) Immediately review the Neon usage dashboard and upgrade or throttle the sync job. (2) Add a circuit-breaker so the scheduler skips backup-sync after consecutive quota failures. (3) Add the DB connection check to the base `/api/healthz` response so the deployment monitor sees degraded status.

3.3 Workflows & build

All five Replit workflows are running: storefront, API server, promo video, mobile app (Expo), and mockup sandbox. The storefront typecheck (`tsc --noEmit`) passes cleanly. The mobile bundler emits a compatibility warning about `@types/react` and `@types/react-dom` versions vs. the installed Expo SDK, but it bundles successfully.

Recommendation: Keep the Expo SDK and type packages aligned; set a CI/typecheck step for the API server and mobile app as well.

4. Design Studio & Mockups

4.1 Architecture

The design studio is a sophisticated SVG/R3F hybrid: product definitions, print zones, and color/tint logic live in `mockups.tsx`; the 2D/3D canvas composition is in `composer.ts`; gesture handling is in `DesignStudio.tsx`; 3D preview is in `ProductViewer3D.tsx`; and cart thumbnails are in `CartViewer3D.tsx`. The codebase has been patched multiple times for blend modes, fit/center/fill actions, mobile undo, and gesture conflicts.

4.2 Confirmed issues

High

Asset naming inconsistency. The repository still contains deprecated mockup files such as `white-hoodie-front-cutout-new.png` and `white-longsleeve-front-cutout-new.png` alongside the recommended `*-cutout-real.png` files. `mockups.tsx` references the `-real` versions, but the continued presence of old files increases the risk of accidental re-introduction, broken links, or CDN confusion. Clean up public/mockups and rename any remaining references.

Medium

Gesture handler fragility. `DesignStudio.tsx` uses `@use-gesture/react` with an explicit `onPointerDown` handler on the SVG canvas. The previous patch merged the handlers, but the implementation is still sensitive to prop ordering and event capturing. Any future refactor could re-introduce the original bug where dragging stops working. Add a regression test or a dedicated pointer-event unit test.

Medium

Print-zone ratio dispute. The user's prior fix command requested different print-zone ratios (e.g., T-shirt 3:4, mug 2.43:1) than what is currently in the code. The current coordinates may not match real-world print dimensions and can make designs look misaligned. A visual QA pass with a printed sample is needed to settle the coordinate set.

Medium

AI generation fallback. When multiple AI image providers are called with `Promise.any`, there is no graceful "all providers failed" state. If every provider errors or times out, the user sees a perpetual spinner. Add a timeout + fallback error message.

Low

Canvas filter cast. The code casts `CanvasRenderingContext2D` as any to apply a blur filter for the print-safe warning. This is brittle on older mobile browsers. Use feature detection instead.

4.3 3D preview

The 3D product viewer was previously using GLB models for apparel, but those models were missing. The team switched to photo-billboard planes (`PhotoMockupMesh`). The memory note warns that color adjustment logic must not be applied to photo planes, otherwise white garments look grey. This is a fragile area: any future color helper refactor can regress the 3D preview. Add a comment in the code and a visual snapshot test for white/black garments.

5. Frontend UX & Commerce Flow

5.1 Product detail pages

High

Product JSON-LD is present but not validated. ProductDetail.tsx uses the SEOHead component with jsonLd arrays including Product and BreadcrumbList. However, the live page fetch did not show a visible application/ld+json block in the first few lines, and the data is assembled from sample review data rather than real reviews. Without testing in Google's Rich Results Test, it is unclear whether the schema is valid. Validate and fix any missing required properties (offers, priceValidUntil, url, sku).

5.2 Checkout

Medium

Client-side price authority. Checkout.tsx computes liveSubtotal, shipping, and total on the client, then sends the amount to the server. The server does validate promo discounts, but a rounding mismatch (e.g., fractional BDT paisa) or a malicious client could create discrepancies. Move the authoritative total calculation to the create-order API and return it to the client for display.

Medium

Advance deposit is 25%. The code correctly uses 25% advance ($\text{Math.ceil}(\text{total} * 0.25)$) across Checkout.tsx, orders.ts, email.ts, telegramWebhook.ts, FAQ.tsx, TermsOfService.tsx, AdminOrders.tsx, and ai.ts. This matches the current policy.

5.3 Cart & wishlist

Cart thumbnails use the same composer pipeline as the design studio. This is good for consistency. No obvious functional bugs were found, but the cart page is not instrumented with purchase-conversion tracking beyond the checkout page.

6. Backend & API

6.1 Security: GitHub PAT in database

Critical

api-server/src/index.ts:142-154 automatically writes the GitHub PAT from the environment (GITHUB_PERSONAL_TOKEN, GITHUB_PERSONAL_ACCESS_TOKEN, or GITHUB_TOKEN) into the settings table with key 'github_token'. If the admin panel is compromised, the attacker can read the PAT and push to the repository. This defeats the purpose of keeping the token in environment secrets.

Recommendation: Stop persisting the PAT in the DB. Store it only in the environment/secret manager. The admin "push to GitHub" feature should read from the environment variable at runtime, or use a short-lived OAuth flow. If the DB setting is needed for self-hosted customers, encrypt it with a key that is not stored in the same settings table.

6.2 Storage upload limits

High

api-server/src/routes/storage.ts defines MAX_UPLOAD_BYTES = 25 MB and validates size in the request body schema. However, the direct-upload endpoint (/storage/upload-direct/:objectId) only enforces the limit while collecting the stream chunks. If the request body is already buffered (Buffer.isBuffer), the check at lines 147-149 catches it, but an extremely large request could still consume memory before reaching the route. Add an early Content-Length check or use a streaming body parser.

6.3 Health endpoint

Low

/api/healthz returns a simple {"status":"ok"}. It does not check the database or Redis connection. With the current DB failover issues, a more informative health response (db: ok/degraded, redis: ok, storage: backend) is needed. The system health endpoint exists but is on a different route and returns a different shape, causing the admin dashboard to show contradictory status. Align the shapes or document them.

6.4 Sitemap

Medium

/api/sitemap.xml is generated and includes lastmod for static pages, categories, products, and blog posts using the product updatedAt column. However, it lacks priority weighting for high-traffic keyword pages and does not include image dimensions. The sitemap is served via /api/sitemap.xml and proxied through /sitemap.xml on CF Pages (per memory). Verify the _redirects rule is still in place.

7. SEO & Performance

7.1 Search visibility

Manual web searches for "TryNex Lifestyle", "trynexshop", and "custom t-shirt bangladesh" did not surface trynexshop.com in the first page of results. The site relies on Unsplash for many product images, which can break (404) silently. Product slugs contain Bengali text in some cases (e.g., "T-Shirt-Combo-2-in-1-Couple-Set" vs "■■■■■■■■ ■■-■■■■■■ ■■■"), which may confuse canonical linking if not handled consistently.

Recommendations: (1) Add verified Google Search Console and submit /sitemap.xml. (2) Fix JSON-LD so Product rich snippets appear. (3) Replace Unsplash dependency with self-hosted images or a CDN. (4) Build

internal backlinks from the keyword landing pages to the catalog. (5) Add review schema with real review data.

7.2 Performance

The homepage is a large SPA. Server response times are fast because Cloudflare serves the static CF Pages shell, but first-page JavaScript bundles can be large. No Core Web Vitals data was collected because PageSpeed/Lighthouse was not run; this is a recommended next step.

Recommendations: (1) Add lazy loading for below-the-fold images. (2) Code-split the design studio and admin bundles. (3) Run Lighthouse and set budgets for LCP and TBT.

8. Mobile App (Expo)

High

trynex-mobile/app/checkout.tsx:22-32 hardcodes the `BD_DISTRICTS` list. If the backend expands shipping regions or renames a district, the mobile app will ship stale options until a new build is released. The web storefront already uses a shared `data/bd-addresses` module. The mobile app should fetch the district list from the API or share the same module.

Medium

Validation UX. The checkout screen uses `Alert.alert` for missing fields. On Expo Web, `Alert.alert` behaves differently than on native and can block the main thread. Convert validation to inline field errors and a non-blocking toast/banner. Also, email is sent as `email.trim() || undefined`, but the API schema may require strict validation; ensure the API accepts optional email with a fallback.

Medium

SDK drift. Metro warns that `@types/react` and `@types/react-dom` versions are newer than expected for the installed Expo SDK. This can cause subtle type/runtime mismatches. Pin the type packages to the Expo-recommended versions.

9. Security & Compliance

Critical

GitHub PAT stored in settings table (see section 6.1).

High

No explicit rate limiting was observed on upload or order endpoints. Add rate-limit middleware (e.g., `express-rate-limit`) to public endpoints and stricter limits on AI generation endpoints to prevent abuse.

Medium

Content-Security-Policy and HSTS headers are not present in the Cloudflare response. Add security headers via Cloudflare Transform Rules or the CF Pages functions.

10. Prioritized 30-Day Fix Plan

Items are ordered by impact and effort. Tackle Week 1 first; Week 2-4 can run in parallel.

10.1 Week 1 — Critical hardening

- **Remove GitHub PAT from DB:** Delete the auto-save block in `api-server/src/index.ts:140-160`. Read the token from environment secrets only. Encrypt any legacy DB entries. (1 day)
- **Fix database health/quota:** Upgrade Neon or add a circuit-breaker in the scheduler. Add DB and Redis status to `/api/healthz`. (1-2 days)
- **Add rate limiting:** Apply `express-rate-limit` to `/api/*` public routes, especially storage uploads and AI generation. (0.5 day)
- **Validate product JSON-LD:** Test a product page in Google's Rich Results Test, fix missing fields, and add real review data. (1 day)

10.2 Week 2 — Conversion & trust

- **Move order total authority to API:** Server-side calculation of subtotal, shipping, discount, and advance in the create-order endpoint. (1.5 days)
- **Mobile checkout refactor:** Replace hardcoded `BD_DISTRICTS` with shared data or API fetch; convert `Alert.alert` to inline validation. (1 day)
- **Design-studio QA:** Remove deprecated `*-cutout-new.png` files; confirm print-zone ratios against printed samples; add a regression test for drag/selection. (2 days)
- **Asset stability:** Migrate product images from Unsplash to self-hosted storage or a reliable CDN with fallbacks. (1-2 days)

10.3 Week 3 — SEO & performance

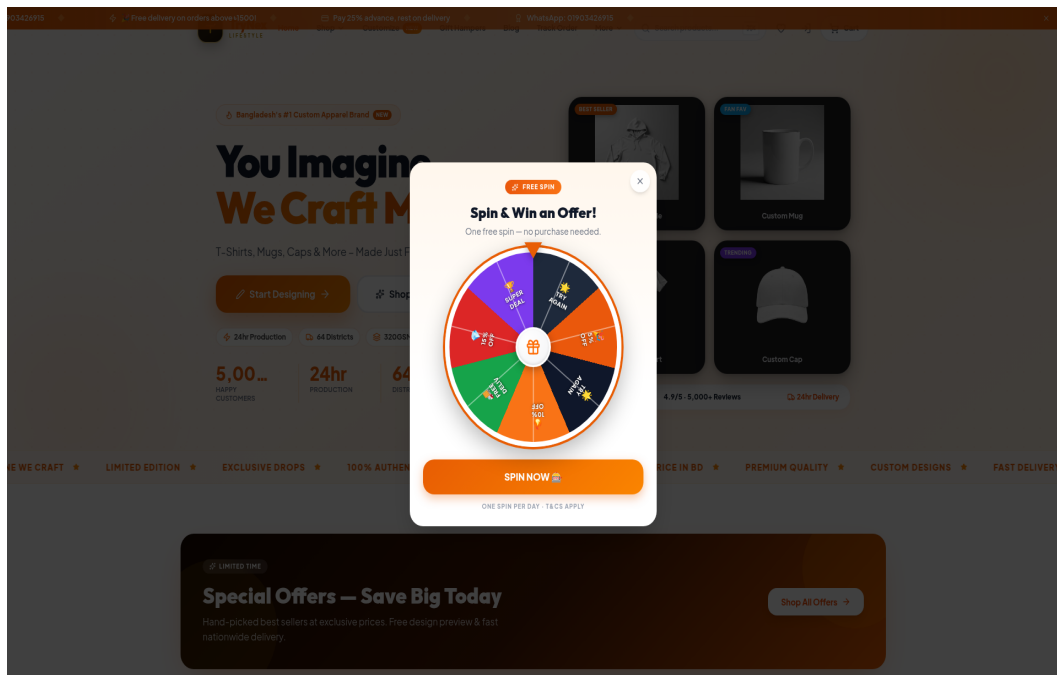
- **Google Search Console:** Verify ownership, submit sitemap, and monitor indexing errors. (0.5 day)
- **Lighthouse budget:** Measure LCP/TBT/CLS, add lazy loading, and code-split design studio. (2 days)
- **Sitemap improvements:** Add image dimensions, priority weighting, and alternate language tags consistently. (0.5 day)
- **Internal linking:** Link keyword landing pages to relevant products and add breadcrumb navigation. (1 day)

10.4 Week 4 — Polish & monitoring

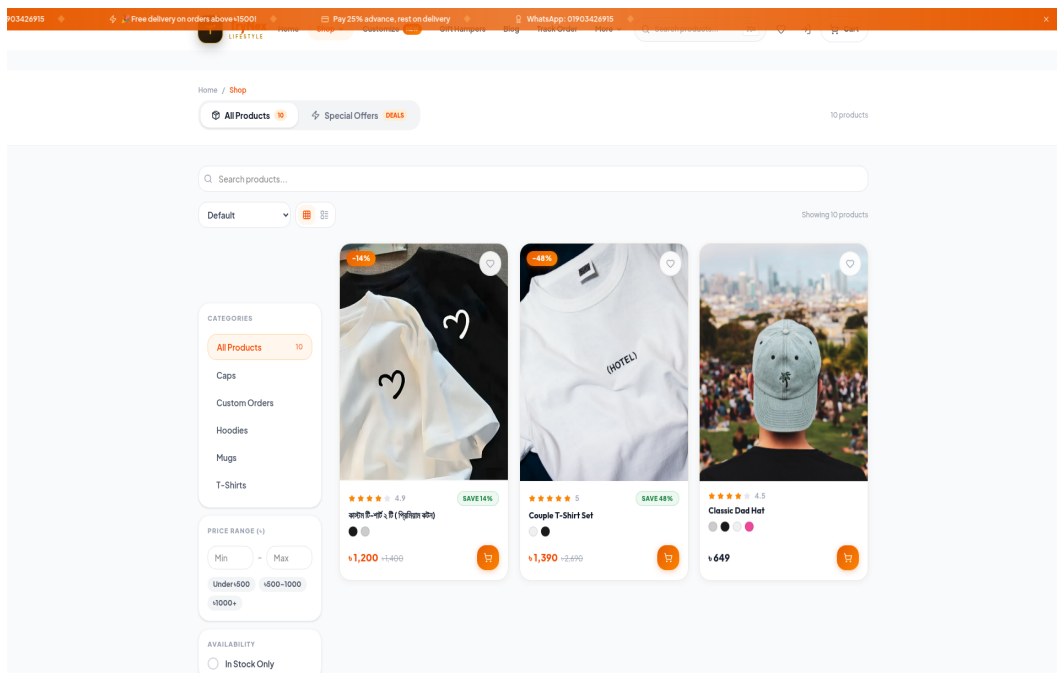
- **Security headers:** Add CSP, HSTS, X-Frame-Options, and Referrer-Policy via Cloudflare. (0.5 day)
- **Mobile SDK alignment:** Pin `@types/react` and `@types/react-dom` to Expo-recommended versions. (0.5 day)
- **Monitoring:** Add Sentry/error-boundary alerts for client crashes and failed API calls. (1-2 days)
- **Documentation:** Update `AUDIT_REPORT.md` and `FIX_PLAN.md` with resolved items and new baselines. (0.5 day)

11. Appendix — Live Screenshots

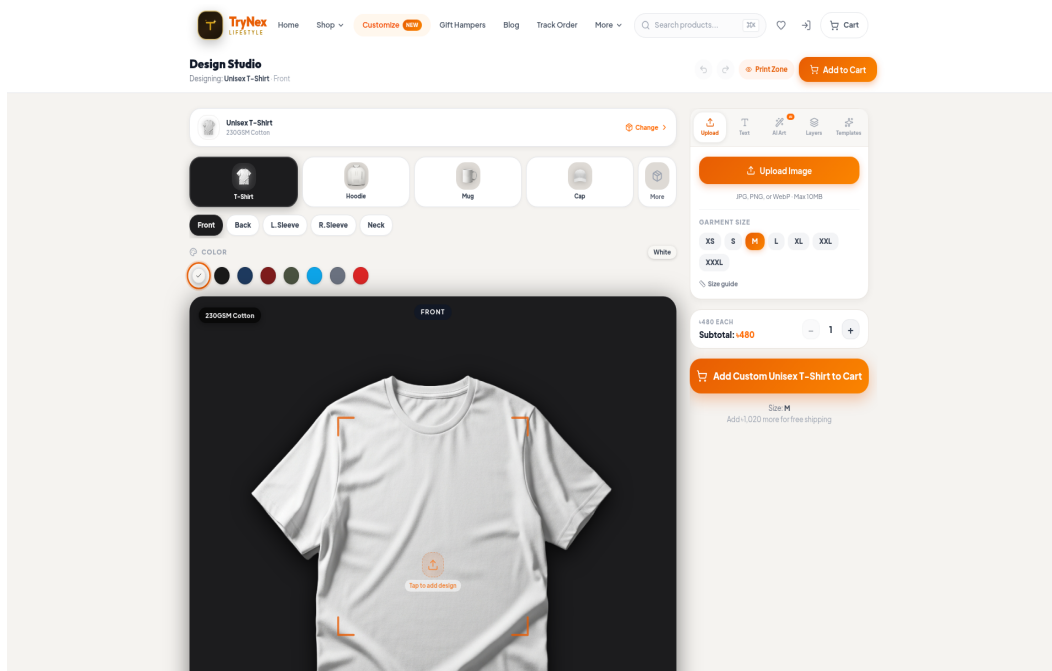
The following screenshots were captured on July 19, 2026 from the live production site.



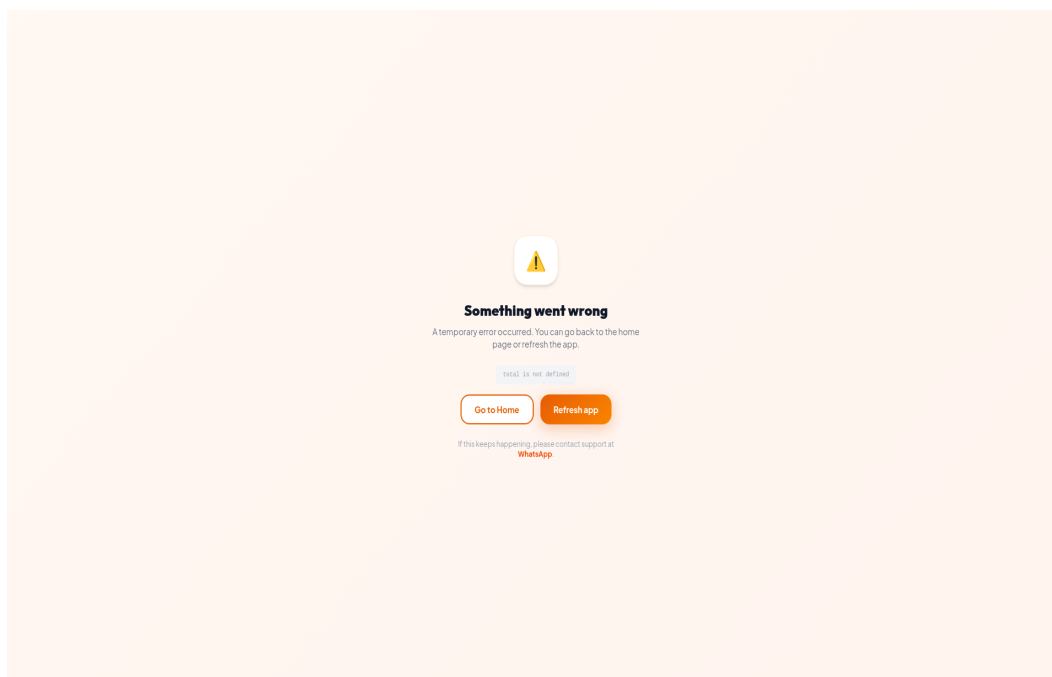
Homepage — <https://trynexshop.com/>



Products page — <https://trynexshop.com/products>



Design Studio — <https://trynexshop.com/design-studio>



Product detail — <https://trynexshop.com/product/couple-tshirt-set>